

Security+ 5.5 · Audits & Assessments

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.5 — Audits & Assessments (2:49) · [vídeo original ↗](#) · [YouTube ↗](#)

Audit: internal (da empresa) vs external (terceiro — certified, regulator); reasons: verificar se controls funcionam, prover cliente/regulador; compliance monitoring CONTÍNUO (não só anual).

💡 Highlights que a prova cobra

- Internal audit = da própria empresa; external = terceiro
- Compliance monitoring: período-contínuo, NÃO só o anual

🎯 Dicas de prova

- 'independent verification by third-party'=external audit

Cenário clássico: 'consultoria externa audita o SGSI'=external audit.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. ISO/IEC 27001 é:

- A)** A norma INTERNACIONAL de gestão de segurança da informação (SGSI)
- B)** Uma lei dos EUA
- C)** Um tipo de firewall
- D)** Um scanner de vulnerabilidade

2. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Compliance monitoring: período-contínuo, NÃO só o anual'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'independent verification by third-party'=external audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'independent verification by third-party'=external audit...

5. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: "consultoria externa audita o SGSI"=external audit.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit....
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Compliance monitoring: período-contínuo, NÃO só o anual'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Compliance monitoring: período-contínuo, NÃO só o anual...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: "independent verification by third-party"=external audit'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'independent verification by third-party'=external audit...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: "consultoria externa audita o SGSI"=external audit.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'consultoria externa audita o SGSI'=external audit....

10. Cenário corporativo (Audits & Assessments): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.5), um analista avalia o seguinte requisito técnico: 'Internal audit = da própria empresa; external = terceiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Internal audit = da própria empresa; external = terceiro...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — A norma INTERNACIONAL de gestão de segurança da informação (SGSI).** ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR).
- 2) C — Implementar a solução correspondente: Internal audit = da própria empresa; exter.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro. As demais alternativas configuram violações graves de
- 3) A — Implementar a solução correspondente: Compliance monitoring: período-contínuo, N.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Compliance monitoring: período-contínuo, NÃO só o anual. As demais alternativas configuram violações graves de c
- 4) D — Implementar a solução correspondente: 'independent verification by third-party' =.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'independent verification by third-party' = external audit. As demais alternativas configuram violações graves de
- 5) B — Implementar a solução correspondente: 'consultoria externa audita o SGSI' = extern.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'consultoria externa audita o SGSI' = external audit.. As demais alternativas configuram violações graves de confo
- 6) B — Implementar a solução correspondente: Internal audit = da própria empresa; exter.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro. As demais alternativas configuram violações graves de
- 7) C — Implementar a solução correspondente: Compliance monitoring: período-contínuo, N.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Compliance monitoring: período-contínuo, NÃO só o anual. As demais alternativas configuram violações graves de c
- 8) B — Implementar a solução correspondente: 'independent verification by third-party' =.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'independent verification by third-party' = external audit. As demais alternativas configuram violações graves de
- 9) D — Implementar a solução correspondente: 'consultoria externa audita o SGSI' = extern.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): 'consultoria externa audita o SGSI' = external audit.. As demais alternativas configuram violações graves de confo
- 10) B — Implementar a solução correspondente: Internal audit = da própria empresa; exter.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.5 (Audits & Assessments): Internal audit = da própria empresa; external = terceiro. As demais alternativas configuram violações graves de

